

NORMA EUROPEA

UNI CEI EN ISO/IEC 27001:2024+A1

OTTOBRE 2024

Versione italiana dell'ottobre 2024

Sicurezza delle informazioni, cybersecurity e protezione della privacy – Sistemi di gestione per la sicurezza delle informazioni – Requisiti

Information security, cybersecurity and privacy protection – Information security management systems – Requirements

TESTO ITALIANO

La presente norma è la versione ufficiale in lingua italiana della norma europea EN ISO/IEC 27001 (edizione luglio 2023) e dell'aggiornamento A1 (edizione settembre 2024).

La presente norma sostituisce la UNI CEI EN ISO/IEC 27001:2024.

ICS 03.100.70; 35.030



COMITATO
ELETTROTECNICO
ITALIANO



SOMMARIO

La norma specifica i requisiti per stabilire, implementare, mantenere e migliorare continuamente un sistema di gestione della sicurezza delle informazioni nel contesto dell'organizzazione.

Il documento include anche i requisiti per la valutazione e il trattamento dei rischi per la sicurezza delle informazioni, adattati alle esigenze dell'organizzazione.

I requisiti stabiliti in questo documento sono generici e si intendono applicabili a tutte le organizzazioni, indipendentemente dal tipo, dalle dimensioni o dalla natura.

La presente edizione della norma si differenzia dalla precedente dalla sola inclusione dell'aggiornamento A1 (edizione settembre 2024) che riguarda le azioni relative al cambiamento climatico.

PREMESSA NAZIONALE

La presente norma costituisce il recepimento, in lingua italiana, della norma europea EN ISO/IEC 27001 (edizione luglio 2023) e dell'aggiornamento A1 (edizione settembre 2024) che assumono così lo status di norma nazionale italiana.

La presente norma è stata elaborata sotto la competenza dell'ente federato all'UNI

UNINFO - Tecnologie Informatiche e loro applicazioni

e del

CEI - Comitato Elettrotecnico Italiano

La presente norma è stata ratificata dal Presidente del CEI, con delibera del 7 ottobre 2024.

La presente norma è stata ratificata dal Presidente dell'UNI ed è entrata a far parte del corpo normativo nazionale il 16 ottobre 2024.

© UNI

Riproduzione vietata ai sensi della Legge 22 aprile 1941 N° 633 e ss.mm.ii.

I contenuti del documento possono essere riprodotti o diffusi solo previa autorizzazione scritta di UNI.

Le norme UNI (così come le EN e le ISO) sono documenti tutelati da copyright e sono disponibili a pagamento. Con l'acquisto di questo documento (e con l'associazione a UNI) si partecipa al mantenimento e alla crescita di un sistema di autoregolamentazione che crea e tiene aggiornato lo stato dell'arte, a garanzia di una qualità disponibile e diffusa.

Le norme UNI sono elaborate grazie al contributo delle parti interessate, tutti i dettagli sull'iter sono riportati nella regolamentazione applicabile, disponibile sul sito www.uni.com (Chi Siamo – Documenti).

Si richiama l'attenzione sulla possibilità che alcuni degli elementi del presente documento possano essere oggetto di diritti di brevetto. UNI non deve essere ritenuto responsabile dell'identificazione di tali diritti di brevetto.

Le norme UNI sono riesaminate periodicamente, pertanto è importante che l'utente si accerti di essere in possesso dell'edizione in vigore. Si raccomanda inoltre di verificare l'esistenza di norme UNI corrispondenti alle norme EN o ISO ove citate nei riferimenti normativi.

INDICE

	PREMESSA CEN ALLA NORMA EN ISO/IEC 27001	1
	PREMESSA CEN ALL'AGGIORNAMENTO A1	2
	PREMESSA ISO ALLA NORMA ISO/IEC 27001	3
	PREMESSA ISO ALL'AGGIORNAMENTO AMD 1	4
	INTRODUZIONE	5
1	SCOPO E CAMPO DI APPLICAZIONE	5
2	RIFERIMENTI NORMATIVI	6
3	TERMINI E DEFINIZIONI	6
4	CONTESTO DELL'ORGANIZZAZIONE	6
4.1	Comprendere l'organizzazione e il suo contesto.....	6
4.2	Comprendere le esigenze e le aspettative delle parti interessate	6
4.3	Determinare il campo di applicazione del sistema di gestione per la sicurezza delle informazioni	6
4.4	Sistema di gestione per la sicurezza delle informazioni.....	7
5	LEADERSHIP	7
5.1	Leadership e impegno.....	7
5.2	Politica	7
5.3	Ruoli, responsabilità e autorità	8
6	PIANIFICAZIONE	8
6.1	Azioni per affrontare rischi e opportunità	8
6.1.1	Generalità.....	8
6.1.2	Valutazione del rischio relativo alla sicurezza delle informazioni.....	8
6.1.3	Trattamento del rischio relativo alla sicurezza delle informazioni	9
6.2	Obiettivi per la sicurezza delle informazioni e pianificazione per conseguirli.....	9
6.3	Pianificazione delle modifiche	10
7	SUPPORTO	10
7.1	Risorse.....	10
7.2	Competenze	10
7.3	Consapevolezza.....	10
7.4	Comunicazione	11
7.5	Informazioni documentate.....	11
7.5.1	Generalità.....	11
7.5.2	Creazione e aggiornamento delle informazioni documentate	11
7.5.3	Controllo delle informazioni documentate	11
8	ATTIVITÀ OPERATIVE	12
8.1	Pianificazione e controllo operativi.....	12
8.2	Valutazione del rischio relativo alla sicurezza delle informazioni	12
8.3	Trattamento del rischio relativo alla sicurezza delle informazioni	12

9	VALUTAZIONE DELLE PRESTAZIONI	12
9.1	Monitoraggio, misurazione, analisi e valutazione	12
9.2	Audit interni.....	13
9.2.1	Generalità	13
9.2.2	Programma degli audit interni	13
9.3	Riesame di direzione.....	13
9.3.1	Generalità	13
9.3.2	Elementi in ingresso al riesame di direzione.....	13
9.3.3	Risultati del riesame di direzione	14
10	MIGLIORAMENTO	
10.1	Miglioramento continuo	14
10.2	Nonconformità e azioni correttive	14
APPENDICE A (normativa)	CONTROLLI DI RIFERIMENTO PER LA SICUREZZA DELLE INFORMAZIONI	15
prospetto A.1	Controlli per la sicurezza delle informazioni.....	15
	BIBLIOGRAFIA	21

PREMESSA CEN ALLA NORMA EN ISO/IEC 27001

Il testo della ISO/IEC 27001:2022 è stato elaborato dal Comitato Tecnico ISO/IEC JTC 1 "Information technology" dell'Organizzazione Internazionale di Normazione (ISO) ed è stato ripreso come EN ISO/IEC 27001:2023 dal Comitato Tecnico CEN-CENELEC/JTC 13 "Cybersecurity and Data Protection" la cui segreteria è affidata al DIN.

Alla presente norma europea deve essere attribuito lo status di norma nazionale, o mediante pubblicazione di un testo identico o mediante notifica di adozione, al più tardi entro gennaio 2024, e le norme nazionali in contrasto devono essere ritirate al più tardi entro gennaio 2024.

Si richiama l'attenzione alla possibilità che alcuni degli elementi del presente documento possano essere oggetto di brevetti. Il CEN-CENELEC non deve essere ritenuto responsabile di avere citato tali brevetti.

Il presente documento sostituisce la EN ISO/IEC 27001:2017.

Qualsiasi commento o richiesta sul presente documento dovrebbe essere rivolta al proprio ente di normazione nazionale. Una lista completa di tali enti è disponibile nei siti web del CEN e del CENELEC.

In conformità alle Regole Comuni CEN/CENELEC, gli enti nazionali di normazione dei seguenti Paesi sono tenuti a recepire la presente norma europea: Austria, Belgio, Bulgaria, Cipro, Croazia, Danimarca, Estonia, Finlandia, Francia, Germania, Grecia, Irlanda, Islanda, Italia, Lettonia, Lituania, Lussemburgo, Malta, Norvegia, Paesi Bassi, Polonia, Portogallo, Regno Unito, Repubblica Ceca, Repubblica di Nord della Macedonia, Romania, Serbia, Slovacchia, Slovenia, Spagna, Svezia, Svizzera, Turchia e Ungheria.

NOTIFICA DI ADOZIONE

Il testo della ISO/IEC 27001:2022 è stato approvato dal CEN-CENELEC come EN ISO/IEC 27001:2023 senza alcuna modifica.

PREMESSA CEN ALL'AGGIORNAMENTO A1

Il testo della ISO/IEC 27001:2022/Amd 1:2024 è stato elaborato dal Comitato Tecnico ISO/IEC JTC 1 "Information technology" dell'Organizzazione Internazionale di Normazione (ISO) ed è stato ripreso come EN ISO/IEC 27001:2023/A1:2024 dal Comitato Tecnico CEN-CENELEC/JTC 13 "Cybersecurity and Data Protection" la cui segreteria è affidata al DIN.

Al presente aggiornamento alla norma europea EN ISO /IEC 27001:2023 deve essere attribuito lo status di norma nazionale, o mediante pubblicazione di un testo identico o mediante notifica di adozione, al più tardi entro marzo 2025, e le norme nazionali in contrasto devono essere ritirate al più tardi entro marzo 2025.

Si richiama l'attenzione alla possibilità che alcuni degli elementi del presente documento possano essere oggetto di brevetti. Il CEN-CENELEC non deve essere ritenuto responsabile di avere citato tali brevetti.

Qualsiasi commento o richiesta sul presente documento dovrebbe essere rivolta al proprio ente di normazione nazionale. Una lista completa di tali enti è disponibile nei siti web del CEN e del CENELEC.

In conformità alle Regole Comuni CEN/CENELEC, gli enti nazionali di normazione dei seguenti Paesi sono tenuti a recepire la presente norma europea: Austria, Belgio, Bulgaria, Cipro, Croazia, Danimarca, Estonia, Finlandia, Francia, Germania, Grecia, Irlanda, Islanda, Italia, Lettonia, Lituania, Lussemburgo, Malta, Norvegia, Paesi Bassi, Polonia, Portogallo, Regno Unito, Repubblica Ceca, Repubblica della Macedonia del Nord, Romania, Serbia, Slovacchia, Slovenia, Spagna, Svezia, Svizzera, Turchia e Ungheria.

NOTIFICA DI ADOZIONE

Il testo della ISO/IEC 27001:2022/Amd 1:2024 è stato approvato dal CEN-CENELEC come EN ISO/IEC 27001:2023/A1:2024 senza alcuna modifica.

PREMESSA ISO ALLA NORMA ISO/IEC 27001

L'ISO (l'Organizzazione Internazionale di Normazione) e l'IEC (la Commissione Elettrotecnica Internazionale) costituiscono il sistema specializzato per la standardizzazione mondiale. Gli organismi nazionali che sono membri dell'ISO o dell'IEC partecipano allo sviluppo delle norme internazionali attraverso comitati tecnici istituiti dalla rispettiva organizzazione per occuparsi di particolari campi di attività tecnica. I comitati tecnici ISO e IEC collaborano in settori di reciproco interesse. Ai lavori partecipano anche altre organizzazioni internazionali, governative e non governative, in collegamento con ISO e IEC.

Le procedure utilizzate per lo sviluppo di questo documento e quelle previste per il suo ulteriore mantenimento sono descritte nelle Direttive ISO/IEC, Parte 1. In particolare, vanno notati i diversi criteri di approvazione necessari per i diversi tipi di documento. Questo documento è stato redatto in conformità con le regole editoriali delle Direttive ISO/IEC, Parte 2 (vedere www.iso.org/directives o www.iec.ch/members_experts/refdocs).

Si richiama l'attenzione sulla possibilità che alcuni elementi del presente documento possano essere oggetto di diritti di brevetto. ISO e IEC non saranno ritenuti responsabili dell'identificazione di uno o di tutti questi diritti di brevetto. I dettagli di eventuali diritti di brevetto identificati durante lo sviluppo del documento saranno nell'Introduzione e/o nell'elenco ISO delle dichiarazioni di brevetto ricevute (vedere www.iso.org/patents) o nell'elenco IEC delle dichiarazioni di brevetto ricevute (vedere <https://patents.iec.ch>).

Qualsiasi nome commerciale utilizzato in questo documento è un'informazione fornita per comodità degli utenti e non costituisce un'approvazione.

Per una spiegazione della natura volontaria delle norme, del significato dei termini e delle espressioni specifici dell'ISO relativi alla valutazione della conformità, nonché per informazioni sull'adesione dell'ISO ai principi relativi agli ostacoli tecnici al commercio (Technical Barriers to Trade, TBT) dell'Organizzazione mondiale del commercio (World Trade Organization, WTO), vedere www.iso.org/iso/foreword.html. Nella IEC, vedere www.iec.ch/understanding-standards.

Questo documento è stato preparato dal Comitato Tecnico Congiunto ISO/IEC JTC 1, *Tecnologie Informatiche*, Sottocomitato SC 27, *Sicurezza delle informazioni, cybersecurity e protezione della privacy*.

Questa terza edizione annulla e sostituisce la seconda edizione (UNI CEI EN ISO/IEC 27001:2017), che è stata tecnicamente aggiornata. Incorpora anche la Rettifica Tecnica ISO/IEC 27001:2013/Cor 1:2014 e ISO/IEC 27001:2013/Cor 2:2015.

I cambiamenti principali sono i seguenti:

- il testo è stato allineato con la struttura armonizzata per i sistemi di gestione e con la UNI CEI EN ISO/IEC 27002:2023.

Eventuali commenti o domande su questo documento dovrebbero essere indirizzati all'organismo di normazione nazionale dell'utilizzatore. Un elenco completo di questi organismi può essere trovato su www.iso.org/members.html e www.iec.ch/national-committees.

PREMESSA ISO ALL'AGGIORNAMENTO AMD 1

L'ISO (l'Organizzazione Internazionale di Normazione) e l'IEC (la Commissione Elettrotecnica Internazionale) costituiscono il sistema specializzato per la standardizzazione mondiale. Gli organismi nazionali che sono membri dell'ISO o dell'IEC partecipano allo sviluppo delle norme internazionali attraverso comitati tecnici istituiti dalla rispettiva organizzazione per occuparsi di particolari campi di attività tecnica. I comitati tecnici ISO e IEC collaborano in settori di reciproco interesse. Ai lavori partecipano anche altre organizzazioni internazionali, governative e non governative, in collegamento con ISO e IEC.

Le procedure utilizzate per lo sviluppo di questo documento e quelle previste per il suo ulteriore mantenimento sono descritte nelle Direttive ISO/IEC, Parte 1. In particolare, vanno notati i diversi criteri di approvazione necessari per i diversi tipi di documento. Questo documento è stato redatto in conformità con le regole editoriali delle Direttive ISO/IEC, Parte 2 (vedere www.iso.org/directives o www.iec.ch/members_experts/refdocs).

Si richiama l'attenzione sulla possibilità che alcuni elementi del presente documento possano essere oggetto di diritti di brevetto. ISO e IEC non saranno ritenuti responsabili dell'identificazione di uno o di tutti questi diritti di brevetto. I dettagli di eventuali diritti di brevetto identificati durante lo sviluppo del documento saranno nell'Introduzione e/o nell'elenco ISO delle dichiarazioni di brevetto ricevute (vedere www.iso.org/patents) o nell'elenco IEC delle dichiarazioni di brevetto ricevute (vedere <https://patents.iec.ch>). L'ISO e l'IEC non devono essere ritenuti responsabili di aver citato alcuni o tutti questi brevetti.

Qualsiasi nome commerciale utilizzato in questo documento è un'informazione fornita per comodità degli utenti e non costituisce un'approvazione.

Per una spiegazione della natura volontaria delle norme, del significato dei termini e delle espressioni specifici dell'ISO relativi alla valutazione della conformità, nonché per informazioni sull'adesione dell'ISO ai principi relativi agli ostacoli tecnici al commercio (Technical Barriers to Trade, TBT) dell'Organizzazione mondiale del commercio (World Trade Organization, WTO), vedere www.iso.org/iso/foreword.html. Nella IEC, vedere www.iec.ch/understanding-standards.

Questo documento è stato preparato dal Comitato Tecnico Congiunto ISO/IEC JTC 1, *Information technology*, Sottocomitato SC 27, *Information security, cybersecurity and privacy protection*, in conformità alla Risoluzione 75/2023 del Technical Management Board.

Eventuali commenti o domande su questo documento dovrebbero essere indirizzati all'organismo di normazione nazionale dell'utilizzatore. Un elenco completo di questi organismi può essere trovato su www.iso.org/members.html e www.iec.ch/national-committees.

INTRODUZIONE

0.1

Generalità

Il presente documento è stato elaborato allo scopo di fornire i requisiti per stabilire, attuare, mantenere e migliorare in modo continuo un sistema di gestione per la sicurezza delle informazioni. L'adozione di un sistema di gestione per la sicurezza delle informazioni è una decisione strategica per un'organizzazione. Stabilire e attuare un sistema di gestione per la sicurezza delle informazioni di un'organizzazione sono influenzati dalle sue necessità e obiettivi, dai suoi requisiti di sicurezza, dai suoi processi organizzativi e dalla sua dimensione e struttura. È previsto che tutti questi fattori cambino nel tempo.

Il sistema di gestione per la sicurezza delle informazioni preserva la riservatezza, l'integrità e la disponibilità delle informazioni mediante l'applicazione di un processo di gestione del rischio e dà fiducia alle parti interessate sull'adeguatezza della gestione dei rischi.

È importante che il sistema di gestione per la sicurezza delle informazioni sia parte integrante dei processi e della struttura gestionale complessiva dell'organizzazione e che la sicurezza delle informazioni sia considerata nella progettazione dei processi, dei sistemi informativi e dei controlli. Ci si attende che un sistema di gestione per la sicurezza delle informazioni sia commisurato alle necessità dell'organizzazione.

Il presente documento può essere utilizzato da parti interne ed esterne al fine di valutare la capacità di un'organizzazione di soddisfare i propri requisiti relativi alla sicurezza delle informazioni.

L'ordine con cui sono presentati i requisiti nella presente norma internazionale non riflettono il loro livello di importanza, né implica un ordine con cui devono essere attuati. Gli elementi delle liste sono numerati solo per finalità di referenziazione.

La EN ISO/IEC 27000 presenta una visione d'insieme e il vocabolario dei sistemi di gestione per la sicurezza delle informazioni, citando la famiglia di norme relative ai sistemi di gestione per la sicurezza delle informazioni (tra cui la ISO/IEC 27003^[2], la ISO/IEC 27004^[3] e la ISO/IEC 27005^[4]), con i termini e le definizioni correlati.

0.2

Compatibilità con altre norme relative ai sistemi di gestione

Il presente documento utilizza la struttura ad alto livello, gli stessi titoli per i punti, il testo identico, i termini comuni e le definizioni fondamentali definite nell'Annex SL delle ISO/IEC Directives, Part 1, Consolidated ISO Supplement, e mantiene quindi la compatibilità con le altre norme relative ai sistemi di gestione che hanno adottato l'Annex SL.

L'approccio comune definito dall'Annex SL è utile a quelle organizzazioni che scelgono di realizzare un unico sistema di gestione che soddisfi i requisiti di due o più norme relative ai sistemi di gestione.

1

SCOPO E CAMPO DI APPLICAZIONE

Il presente documento specifica i requisiti per stabilire, attuare, mantenere e migliorare in modo continuo un sistema di gestione per la sicurezza delle informazioni nel contesto di un'organizzazione. Il presente documento include anche i requisiti per la valutazione e il trattamento dei rischi relativi alla sicurezza delle informazioni adattati alle necessità dell'organizzazione. I requisiti stabiliti dal presente documento sono di carattere generale e predisposti per essere applicabili a tutte le organizzazioni, indipendentemente dalla loro tipologia, dimensione e natura. L'esclusione di qualunque requisito specificato nei punti dal 4 al 10 non è accettabile quando un'organizzazione dichiara la sua conformità al presente documento.

2 RIFERIMENTI NORMATIVI

I seguenti documenti, in tutto o in parte, sono richiamati con carattere normativo nel presente documento e sono indispensabili per la sua applicazione. Per quanto riguarda i riferimenti datati, si applica esclusivamente l'edizione citata. Per i riferimenti non datati vale l'ultima edizione del documento a cui si fa riferimento (compresi gli aggiornamenti).

ISO/IEC 27000 Information technology (IT) – Tecniche di sicurezza – Sistemi di gestione per la sicurezza delle informazioni – Visione d'insieme e vocabolario

3 TERMINI E DEFINIZIONI

Ai fini del presente documento si applicano i termini e le definizioni specificati dalla ISO/IEC 27000.

ISO e IEC mantengono dei database di termini utilizzati nella normazione e reperibili ai seguenti indirizzi:

- ISO Online browsing platform: disponibile all'indirizzo <https://www.iso.org/obp>
- IEC Electropedia: disponibile all'indirizzo <https://www.electropedia.org/>

4 CONTESTO DELL'ORGANIZZAZIONE

4.1 Comprendere l'organizzazione e il suo contesto

L'organizzazione deve individuare i fattori esterni e interni che sono rilevanti per le sue finalità e che influenzano la sua capacità di conseguire i risultati attesi per il proprio sistema di gestione per la sicurezza delle informazioni.

Nota La determinazione di questi fattori fa riferimento alla definizione del contesto esterno e interno dell'organizzazione considerato al punto 5.4.1 della ISO 31000:2018^[5].

L'organizzazione deve stabilire se il cambiamento climatico sia un fattore rilevante.

4.2 Comprendere le esigenze e le aspettative delle parti interessate

L'organizzazione deve individuare:

- le parti interessate rilevanti per il sistema di gestione per la sicurezza delle informazioni;
- i requisiti pertinenti di tali parti interessate;
- quali di questi requisiti si vogliono gestire attraverso il sistema di gestione per la sicurezza delle informazioni.

Nota I requisiti delle parti interessate possono includere requisiti cogenti^{*)} e obblighi contrattuali.

Nota Le parti interessate rilevanti possono avere requisiti relativi ai cambiamenti climatici.

4.3 Determinare il campo di applicazione del sistema di gestione per la sicurezza delle informazioni

L'organizzazione deve determinare i confini e l'applicabilità del sistema di gestione per la sicurezza delle informazioni per stabilirne il campo di applicazione.

Nello stabilire il campo di applicazione, l'organizzazione deve considerare:

- i fattori esterni e interni di cui al punto 4.1;
- i requisiti di cui al punto 4.2;
- le interfacce e le interdipendenze tra le attività svolte dall'organizzazione, e quelle svolte da altre organizzazioni.

Il campo di applicazione deve essere disponibile come informazione documentata.

*) Nota nazionale - Per "requisiti cogenti" si intendono, nel seguito, quelli stabiliti da leggi, regolamenti, direttive (requisiti legali) e prescrizioni obbligatorie in genere.

4.4 Sistema di gestione per la sicurezza delle informazioni

L'organizzazione deve stabilire, attuare, mantenere e migliorare in modo continuo un sistema di gestione per la sicurezza delle informazioni, compresi i processi necessari e le loro interazioni, in conformità ai requisiti del presente documento.

5 LEADERSHIP

5.1 Leadership e impegno

L'alta direzione deve dimostrare leadership e impegno in riferimento al sistema di gestione per la sicurezza delle informazioni:

- a) assicurando che siano stabiliti la politica e gli obiettivi per la sicurezza delle informazioni e che essi siano compatibili con gli indirizzi strategici dell'organizzazione;
- b) assicurando l'integrazione dei requisiti del sistema di gestione per la sicurezza delle informazioni nei processi di business dell'organizzazione;
- c) assicurando la disponibilità delle risorse necessarie al sistema di gestione per la sicurezza delle informazioni;
- d) comunicando l'importanza di una gestione per la sicurezza delle informazioni efficace, e della conformità ai requisiti del sistema di gestione per la sicurezza delle informazioni;
- e) assicurando che il sistema di gestione per la sicurezza delle informazioni consegua i risultati attesi;
- f) guidando e supportando le persone affinché contribuiscano all'efficacia del sistema di gestione per la sicurezza delle informazioni;
- g) promuovendo il miglioramento continuo;
- h) fornendo supporto agli altri pertinenti ruoli gestionali per dimostrare la loro leadership, così come essa si applica alle rispettive aree di responsabilità.

Nota Nel presente documento, il termine "business" può essere inteso, in senso ampio, come riferito a quelle attività che caratterizzano la ragion d'essere dell'organizzazione.

5.2 Politica

L'alta direzione deve stabilire una politica per la sicurezza delle informazioni che:

- a) sia appropriata alle finalità dell'organizzazione;
- b) costituisca un quadro di riferimento per fissare gli obiettivi per la sicurezza delle informazioni;
- c) comprenda l'impegno a soddisfare i requisiti applicabili;
- d) comprenda l'impegno per il miglioramento continuo del sistema di gestione per la sicurezza delle informazioni.

La politica per la sicurezza delle informazioni deve:

- e) essere disponibile come informazione documentata;
- f) essere comunicata all'interno dell'organizzazione;
- g) essere disponibile alle parti interessate, come appropriato.

5.3 Ruoli, responsabilità e autorità

L'alta direzione deve assicurare che le responsabilità e le autorità per i ruoli pertinenti siano assegnate e comunicate all'interno dell'organizzazione.

L'alta direzione deve assegnare le responsabilità e autorità per:

- a) assicurare che il sistema di gestione per la sicurezza delle informazioni sia conforme ai requisiti del presente documento;
- b) riferire all'alta direzione sulle prestazioni del sistema di gestione per la sicurezza delle informazioni.

Nota L'alta direzione può anche assegnare responsabilità e autorità per riferire all'interno dell'organizzazione sulle prestazioni del sistema di gestione per la sicurezza delle informazioni.

6 PIANIFICAZIONE

6.1 Azioni per affrontare rischi e opportunità

6.1.1 Generalità

Nel pianificare il sistema di gestione per la sicurezza delle informazioni, l'organizzazione deve considerare i fattori di cui al punto 4.1 e i requisiti di cui al punto 4.2 e determinare i rischi e le opportunità che è necessario affrontare per:

- a) fornire assicurazione che il sistema di gestione per la sicurezza delle informazioni possa conseguire i risultati attesi;
- b) prevenire, o ridurre, gli effetti indesiderati;
- c) conseguire il miglioramento continuo.

L'organizzazione deve pianificare:

- d) le azioni per affrontare questi rischi e opportunità;
- e) le modalità per:
 - 1) integrare e attuare le azioni nei processi del proprio sistema di gestione per la sicurezza delle informazioni;
 - 2) valutare l'efficacia di tali azioni.

6.1.2 Valutazione del rischio relativo alla sicurezza delle informazioni

L'organizzazione deve definire e applicare un processo di valutazione del rischio relativo alla sicurezza delle informazioni che:

- a) stabilisca e mantenga i criteri di rischio relativo alla sicurezza delle informazioni, che includano:
 - 1) i criteri per l'accettazione del rischio;
 - 2) i criteri per effettuare valutazioni del rischio relativo alla sicurezza delle informazioni;
- b) assicuri che ripetute valutazioni del rischio relativo alla sicurezza delle informazioni producano risultati coerenti, validi e confrontabili tra loro;
- c) identifichi i rischi relativi alla sicurezza delle informazioni:
 - 1) applicando il processo di valutazione del rischio relativo alla sicurezza delle informazioni per identificare i rischi associati alla perdita di riservatezza, di integrità e di disponibilità delle informazioni incluse nel campo di applicazione del sistema di gestione per la sicurezza delle informazioni;
 - 2) identificando i responsabili dei rischi;

- d) analizz i rischi relativi alla sicurezza delle informazioni:
 - 1) valutando le possibili conseguenze che risulterebbero se i rischi identificati al punto 6.1.2 c) 1) si concretizzassero;
 - 2) valutando la realistica verosimiglianza del concretizzarsi dei rischi identificati al punto 6.1.2 c) 1);
 - 3) determinando i livelli di rischio;
- e) ponderi i rischi relativi alla sicurezza delle informazioni:
 - 1) comparando i risultati dell'analisi del rischio con i criteri di rischio stabiliti al punto 6.1.2.a);
 - 2) stabilendo le priorità dei rischi analizzati per il trattamento del rischio.

L'organizzazione deve conservare informazioni documentate sul processo di valutazione del rischio relativo alla sicurezza delle informazioni.

6.1.3

Trattamento del rischio relativo alla sicurezza delle informazioni

L'organizzazione deve definire e applicare un processo di trattamento del rischio relativo alla sicurezza delle informazioni per:

- a) selezionare le adeguate opzioni per il trattamento del rischio relativo alla sicurezza delle informazioni, tenendo in considerazione i risultati della valutazione del rischio;
- b) determinare tutti i controlli necessari per attuare l'opzione o le opzioni selezionate per il trattamento del rischio relativo alla sicurezza delle informazioni;

Nota 1 Le organizzazioni possono progettare i controlli come richiesto o identificarli da qualsiasi fonte.

- c) confrontare i controlli determinati al punto 6.1.3.b) con quelli nell'Appendice A e verificare che non siano stati omessi controlli necessari;

Nota 2 L'Appendice A riporta una lista di possibili controlli per la sicurezza delle informazioni. Gli utilizzatori di questo documento sono indirizzati all'Appendice A per assicurare che non siano omessi controlli necessari per la sicurezza delle informazioni.

Nota 3 I controlli per la sicurezza delle informazioni riportati nell'Appendice A non sono esaustivi, e ulteriori controlli per la sicurezza delle informazioni possono essere inclusi se necessario.

- d) redigere una Dichiarazione di applicabilità che riporti:
 - i controlli necessari (vedere i punti 6.1.3 b) e c));
 - le giustificazioni per la loro inclusione;
 - se i controlli necessari sono implementati o meno;
 - le giustificazioni per l'esclusione dei controlli dell'Appendice A.
- e) formulare un piano di trattamento del rischio relativo alla sicurezza delle informazioni;
- f) ottenere l'approvazione del piano di trattamento del rischio relativo alla sicurezza delle informazioni e l'accettazione dei rischi residui relativi alla sicurezza delle informazioni da parte dei responsabili dei rischi.

L'organizzazione deve conservare informazioni documentate sul processo di trattamento del rischio relativo alla sicurezza delle informazioni.

Nota 4 I processi di valutazione e trattamento del rischio relativo alla sicurezza delle informazioni riportati nel presente documento sono allineati con i principi e le linee guida generali fornite dalla UNI ISO 31000^[5].

6.2

Obiettivi per la sicurezza delle informazioni e pianificazione per conseguirli

L'organizzazione deve stabilire gli obiettivi per la sicurezza delle informazioni relativi alle funzioni e ai livelli pertinenti. Gli obiettivi per la sicurezza delle informazioni devono:

- a) essere coerenti con la politica per la sicurezza delle informazioni;
- b) essere misurabili (se praticabile);
- c) tenere in considerazione i requisiti applicabili e i risultati della valutazione e del trattamento del rischio;
- d) essere monitorati;

- e) essere comunicati;
- f) essere aggiornati come appropriato;
- g) essere disponibili come informazioni documentate.

L'organizzazione deve conservare informazioni documentate sugli obiettivi per la sicurezza delle informazioni,

Nel pianificare come raggiungere i propri obiettivi per la sicurezza delle informazioni, l'organizzazione deve determinare:

- h) cosa sarà fatto;
- i) quali risorse saranno richieste;
- j) chi ne sarà responsabile;
- k) quando sarà completato;
- l) come saranno valutati i risultati.

6.3 Pianificazione delle modifiche

Quando l'organizzazione determina l'esigenza di modifiche al sistema di gestione per la sicurezza delle informazioni, queste devono essere eseguite in modo pianificato.

7 SUPPORTO

7.1 Risorse

L'organizzazione deve determinare e fornire le risorse necessarie per l'istituzione, l'attuazione, il mantenimento e il miglioramento continuo del sistema di gestione per la sicurezza delle informazioni.

7.2 Competenze

L'organizzazione deve:

- a) determinare le competenze necessarie per le persone che svolgono attività lavorative sotto il suo controllo e che influenzano le sue prestazioni relative alla sicurezza delle informazioni;
- b) assicurare che queste persone siano competenti sulla base di istruzione, formazione, o esperienza appropriate;
- c) ove applicabile, intraprendere azioni per acquisire le necessarie competenze e valutare l'efficacia delle azioni intraprese;
- d) conservare appropriate informazioni documentate quale evidenza delle competenze.

Nota Le azioni applicabili possono comprendere, per esempio: l'erogazione di formazione, l'affiancamento o la riallocazione di persone attualmente impiegate; oppure l'assunzione o l'incarico a contratto di persone competenti.

7.3 Consapevolezza

Le persone che svolgono un'attività lavorativa sotto il controllo dell'organizzazione devono essere consapevoli:

- a) della politica per la sicurezza delle informazioni;
- b) del proprio contributo all'efficacia del sistema di gestione per la sicurezza delle informazioni, compresi i benefici derivanti dal miglioramento delle prestazioni relative alla sicurezza delle informazioni;
- c) delle implicazioni derivanti dal non essere conformi ai requisiti del sistema di gestione per la sicurezza delle informazioni.

7.4

Comunicazione

L'organizzazione deve determinare le comunicazioni interne ed esterne pertinenti al sistema di gestione per la sicurezza delle informazioni, includendo:

- a) l'argomento della comunicazione;
- b) quando comunicare;
- c) con chi comunicare;
- d) come comunicare.

7.5

Informazioni documentate

7.5.1

Generalità

Il sistema di gestione per la sicurezza delle informazioni dell'organizzazione deve comprendere:

- a) le informazioni documentate richieste dal presente documento;
- b) le informazioni documentate che l'organizzazione determina come necessarie per l'efficacia del sistema di gestione per la sicurezza delle informazioni.

Nota Il livello di dettaglio delle informazioni documentate di un sistema di gestione per la sicurezza delle informazioni può variare da un'organizzazione all'altra in base a:

- 1) la dimensione dell'organizzazione e il suo tipo di attività, processi, prodotti e servizi;
- 2) la complessità dei processi e delle loro interazioni;
- 3) la competenza delle persone.

7.5.2

Creazione e aggiornamento delle informazioni documentate

Nel creare e aggiornare le informazioni documentate, l'organizzazione deve assicurare:

- a) adeguata identificazione e descrizione (per esempio titolo, data, autore o numero di riferimento);
- b) appropriati formato (per esempio lingua, versione del software, grafica) e supporto (per esempio cartaceo, elettronico);
- c) appropriati riesame e approvazione in merito all'idoneità e all'adeguatezza.

7.5.3

Controllo delle informazioni documentate

Le informazioni documentate richieste dal sistema di gestione per la sicurezza delle informazioni e dal presente documento devono essere tenute sotto controllo per assicurare che;

- a) siano disponibili e idonee all'utilizzo, dove e quando necessario;
- b) siano adeguatamente protette (per esempio da perdita di riservatezza, utilizzo improprio, o perdita d'integrità).

Per tenere sotto controllo le informazioni documentate, l'organizzazione deve intraprendere le seguenti attività, come applicabile:

- c) distribuzione, accesso, reperimento e utilizzo;
- d) archiviazione e preservazione, compreso il mantenimento della leggibilità;
- e) controllo dei cambiamenti (per esempio controllo delle versioni);
- f) conservazione e successive disposizioni.

Le informazioni documentate di origine esterna, ritenute necessarie dall'organizzazione per la pianificazione e per il funzionamento del sistema di gestione per la sicurezza delle informazioni, devono essere identificate, come appropriato, e tenute sotto controllo.

Nota L'accesso può comportare una decisione in merito ai permessi di sola visione delle informazioni documentate, o ai permessi e autorità per visualizzarle e modificarle.

8 ATTIVITÀ OPERATIVE

8.1 Pianificazione e controllo operativi

L'organizzazione deve pianificare, attuare e tenere sotto controllo i processi necessari per soddisfare i requisiti e per attuare le azioni determinate al punto 6:

- stabilendo i criteri per i processi;
- attuando il controllo dei processi, in conformità ai criteri.

Devono essere disponibili le informazioni documentate nella misura necessaria a ritenere che i processi siano stati effettuati come pianificato.

L'organizzazione deve tenere sotto controllo i cambiamenti pianificati e riesaminare le conseguenze dei cambiamenti involontari, intraprendendo azioni per mitigare ogni effetto negativo, come necessario.

L'organizzazione deve assicurare che i processi, prodotti o servizi pertinenti al sistema di gestione per la sicurezza delle informazioni affidati all'esterno siano tenuti sotto controllo.

8.2 Valutazione del rischio relativo alla sicurezza delle informazioni

L'organizzazione deve effettuare le valutazioni del rischio relativo alla sicurezza delle informazioni a intervalli pianificati o quando sono proposti o si verificano cambiamenti significativi, considerando i criteri stabiliti al punto 6.1.2 a).

L'organizzazione deve conservare informazioni documentate sui risultati delle valutazioni del rischio relativo alla sicurezza delle informazioni.

8.3 Trattamento del rischio relativo alla sicurezza delle informazioni

L'organizzazione deve attuare il piano di trattamento del rischio relativo alla sicurezza delle informazioni.

L'organizzazione deve conservare informazioni documentate sui risultati del trattamento del rischio relativo alla sicurezza delle informazioni.

9 VALUTAZIONE DELLE PRESTAZIONI

9.1 Monitoraggio, misurazione, analisi e valutazione

L'organizzazione deve determinare:

- a) cosa è necessario monitorare e misurare, compresi i processi e i controlli relativi alla sicurezza delle informazioni;
- b) i metodi per il monitoraggio, la misurazione, l'analisi e la valutazione, come applicabile, per assicurare risultati validi. I metodi selezionati dovrebbero produrre risultati comparabili e ripetibili affinché siano considerati validi;
- c) quando i monitoraggi e le misurazioni devono essere eseguiti;
- d) chi deve monitorare e misurare;
- e) quando i risultati dei monitoraggi e delle misurazioni devono essere analizzati e valutati;
- f) chi deve analizzare e valutare questi risultati.

Devono essere disponibili informazioni documentate quale evidenza dei risultati.

L'organizzazione deve valutare le prestazioni e l'efficacia del sistema di gestione per la sicurezza delle informazioni.

9.2 Audit interni

9.2.1 Generalità

L'organizzazione deve condurre, a intervalli pianificati, audit interni allo scopo di fornire informazioni per accertare se il sistema di gestione per la sicurezza delle informazioni:

- a) è conforme ai:
 - 1) requisiti propri dell'organizzazione relativi al suo sistema di gestione per la sicurezza delle informazioni;
 - 2) requisiti del presente documento;
- b) è efficacemente attuato e mantenuto.

9.2.2 Programma degli audit interni

L'organizzazione deve pianificare, stabilire, attuare e mantenere uno o più programmi di audit comprensivi di frequenza, metodi, responsabilità, requisiti di pianificazione e reporting.

Nello stabilire uno o più programmi per gli audit interni, l'organizzazione deve tenere in considerazione l'importanza dei processi coinvolti e i risultati degli audit precedenti.

L'organizzazione deve:

- a) definire gli obiettivi, i criteri di audit e il campo di applicazione per ciascun audit;
- b) selezionare gli auditor e condurre gli audit in modo tale da assicurare l'obiettività e l'imparzialità del processo di audit;
- c) assicurare che i risultati degli audit siano riportati ai responsabili pertinenti.

Devono essere disponibili informazioni documentate quale evidenza dell'attuazione dei programmi di audit e dei risultati degli audit.

9.3 Riesame di direzione

9.3.1 Generalità

L'alta direzione deve, a intervalli pianificati, riesaminare il sistema di gestione per la sicurezza delle informazioni dell'organizzazione, per assicurarne la continua idoneità, adeguatezza ed efficacia.

9.3.2 Elementi in ingresso al riesame di direzione

Il riesame di direzione deve includere considerazioni su:

- a) lo stato delle azioni derivanti da precedenti riesami di direzione;
- b) i cambiamenti nei fattori esterni e interni che sono rilevanti per il sistema di gestione per la sicurezza delle informazioni;
- c) cambiamenti nelle esigenze e aspettative delle parti interessate che sono pertinenti al sistema di gestione per la sicurezza delle informazioni;
- d) le informazioni sulle prestazioni relative alla sicurezza delle informazioni, compresi gli andamenti (trend) relativi:
 - 1) alle non conformità e alle azioni correttive;
 - 2) ai risultati dei monitoraggi e delle misurazioni;
 - 3) ai risultati di audit;
 - 4) al raggiungimento degli obiettivi per la sicurezza delle informazioni;
- e) le informazioni di ritorno dalle parti interessate;
- f) i risultati della valutazione del rischio e lo stato del piano di trattamento del rischio;
- g) le opportunità per il miglioramento continuo.

9.3.3

Risultati del riesame di direzione

I risultati del riesame di direzione devono comprendere decisioni relative alle opportunità per il miglioramento continuo e ogni esigenza di cambiamento al sistema di gestione per la sicurezza delle informazioni.

Devono essere disponibili informazioni documentate quale evidenza dei risultati dei riesami di direzione.

10

Miglioramento

10.1

Miglioramento continuo

L'organizzazione deve migliorare in modo continuo l'idoneità, l'adeguatezza e l'efficacia del sistema di gestione per la sicurezza delle informazioni.

10.2

Nonconformità e azioni correttive

Quando si verifica una non conformità, l'organizzazione deve:

- a) reagire alla non conformità, e, come applicabile:
 - 1) intraprendere azioni per tenerla sotto controllo e correggerla;
 - 2) affrontarne le conseguenze;
- b) valutare l'esigenza di azioni per eliminare la causa o le cause di non conformità, in modo che non si ripeta o non si verifichi altrove:
 - 1) riesaminando la non conformità;
 - 2) determinando le cause della non conformità;
 - 3) determinando se esistono o possono verificarsi non conformità simili;
- c) attuare ogni azione necessaria;
- d) riesaminare l'efficacia di ogni azione correttiva intrapresa;
- e) apportare, se necessario, modifiche al sistema di gestione per la sicurezza delle informazioni.

Le azioni correttive devono essere adeguate agli effetti delle non conformità riscontrate.

Devono essere disponibili informazioni documentate quale evidenza:

- f) della natura delle non conformità e di ogni successiva azione intrapresa;
- g) dei risultati di ogni azione correttiva.

APPENDICE A CONTROLLI DI RIFERIMENTO PER LA SICUREZZA DELLE INFORMAZIONI
(normativa)

I controlli per la sicurezza delle informazioni elencati nel prospetto A.1 sono ripresi direttamente dai punti da 5 a 8 nella UNI CEI EN ISO/IEC 27002:2023 [1] e allineati a essi e devono essere utilizzati nel contesto del punto 6.1.3.

prospetto A.1 Controlli per la sicurezza delle informazioni		
5	Controlli organizzativi	
5.1	Politiche per la sicurezza delle informazioni	Controllo La politica per la sicurezza delle informazioni e le politiche specifiche devono essere definite, approvate dalla direzione, pubblicate, comunicate e accettate dal personale pertinente e dalle parti interessate pertinenti e riesaminate a intervalli pianificati e quando si verificano cambiamenti significativi.
5.2	Ruoli e responsabilità per la sicurezza delle informazioni	Controllo I ruoli e le responsabilità per la sicurezza delle informazioni devono essere definiti e assegnati in base alle esigenze dell'organizzazione.
5.3	Separazione dei compiti	Controllo I compiti e le aree di responsabilità in conflitto devono essere separati.
5.4	Responsabilità della direzione	Controllo La direzione deve richiedere a tutto il personale di applicare la sicurezza delle informazioni in conformità con la politica per la sicurezza delle informazioni, le politiche specifiche e le procedure dell'organizzazione in vigore.
5.5	Contatti con le autorità	Controllo L'organizzazione deve stabilire e mantenere i contatti con le autorità competenti.
5.6	Contatti con gruppi specialistici	Controllo L'organizzazione deve stabilire e mantenere contatti con gruppi specialistici o altri forum di sicurezza specializzati e associazioni professionali.
5.7	Threat intelligence	Controllo Le informazioni relative alle minacce alla sicurezza delle informazioni devono essere raccolte e analizzate per produrre threat intelligence.
5.8	Sicurezza delle informazioni nella gestione dei progetti	Controllo La sicurezza delle informazioni deve essere integrata nella gestione dei progetti.
5.9	Inventario delle informazioni e degli altri asset relativi	Controllo Deve essere sviluppato e mantenuto un inventario delle informazioni e degli altri asset relativi, compresi i responsabili.
5.10	Uso accettabile delle informazioni e degli altri asset relativi	Controllo Le regole per l'uso accettabile e le procedure per il trattamento delle informazioni e degli altri asset relativi devono essere identificate, documentate e attuate.
5.11	Resituzione degli asset	Controllo Il personale e le altre parti interessate, a seconda dei casi, devono restituire tutti gli asset dell'organizzazione in loro possesso in caso di cambiamento o cessazione del rapporto di lavoro, del contratto o dell'accordo.
5.12	Classificazione delle informazioni	Controllo Le informazioni devono essere classificate in base alle esigenze di sicurezza delle informazioni dell'organizzazione sulla base dei requisiti di riservatezza, integrità, disponibilità e delle parti interessate pertinenti.
5.13	Etichettatura delle informazioni	Controllo Un insieme appropriato di procedure per l'etichettatura delle informazioni deve essere sviluppato e implementato in conformità con lo schema di classificazione delle informazioni adottato dall'organizzazione.
5.14	Trasferimento delle informazioni	Controllo Devono essere in vigore regole, procedure o accordi per il trasferimento delle informazioni per tutte le tipologie di strutture di trasferimento all'interno dell'organizzazione e tra l'organizzazione e altre parti.

prospetto A.1 **Controlli per la sicurezza delle informazioni (Continua)**

5.15	Controllo degli accessi	Controllo Le regole per controllare l'accesso fisico e logico alle informazioni e agli altri asset relativi devono essere stabilite e implementate sulla base dei requisiti di business e di sicurezza delle informazioni.
5.16	Gestione delle identità	Controllo L'intero ciclo di vita delle identità deve essere gestito.
5.17	Informazioni di autenticazione	Controllo L'assegnazione e la gestione delle informazioni di autenticazione devono essere controllate da un processo gestionale, che preveda di informare il personale in merito al trattamento appropriato delle informazioni di autenticazione.
5.18	Diritti d'accesso	Controllo I diritti di accesso alle informazioni e agli altri asset relativi devono essere forniti, riesaminati, modificati e rimossi in accordo con la politica specifica e le regole per il controllo degli accessi dell'organizzazione.
5.19	Sicurezza delle informazioni nelle relazioni con i fornitori	Controllo Devono essere stabiliti e implementati processi e procedure per gestire i rischi della sicurezza delle informazioni associati all'utilizzo di prodotti o servizi del fornitore.
5.20	Sicurezza delle informazioni negli accordi con i fornitori	Controllo I requisiti di sicurezza delle informazioni pertinenti devono essere stabiliti e concordati con ciascun fornitore in base al tipo di rapporto con il fornitore.
5.21	Gestione della sicurezza delle informazioni nella filiera di fornitura per l'ICT	Controllo Devono essere definiti e attuati processi e procedure per gestire i rischi relativi alla sicurezza delle informazioni associati alla filiera di fornitura di prodotti e servizi ICT.
5.22	Monitoraggio, riesame e gestione dei cambiamenti dei servizi dei fornitori	Controllo L'organizzazione deve monitorare, riesaminare, valutare e gestire regolarmente i cambiamenti nelle pratiche di sicurezza delle informazioni dei fornitori e nell'erogazione dei servizi.
5.23	Sicurezza delle informazioni per l'utilizzo di servizi cloud	Controllo I processi per l'acquisizione, l'utilizzo, la gestione e l'uscita dai servizi cloud devono essere stabiliti in conformità con i requisiti di sicurezza delle informazioni dell'organizzazione.
5.24	Pianificazione e preparazione per la gestione degli incidenti relativi alla sicurezza delle informazioni	Controllo L'organizzazione deve pianificare e prepararsi per la gestione degli incidenti relativi alla sicurezza delle informazioni definendo, stabilendo e comunicando processi, ruoli e responsabilità di gestione degli incidenti relativi alla sicurezza delle informazioni.
5.25	Valutazione e decisione sugli eventi relativi alla sicurezza delle informazioni	Controllo L'organizzazione deve valutare gli eventi relativi alla sicurezza delle informazioni e decidere se devono essere classificati come incidenti relativi alla sicurezza delle informazioni.
5.26	Risposta agli incidenti relativi alla sicurezza delle informazioni	Controllo Gli incidenti relativi alla sicurezza delle informazioni devono essere risolti secondo le procedure documentate.
5.27	Apprendimento dagli incidenti relativi alla sicurezza delle informazioni	Controllo Le conoscenze acquisite dagli incidenti relativi alla sicurezza delle informazioni devono essere utilizzate per rafforzare e migliorare i controlli di sicurezza delle informazioni.
5.28	Raccolta di prove	Controllo L'organizzazione deve stabilire e attuare procedure per l'identificazione, la raccolta, l'acquisizione e la conservazione delle prove relative agli eventi relativi alla sicurezza delle informazioni.
5.29	Sicurezza delle informazioni durante le interruzioni	Controllo L'organizzazione deve pianificare come mantenere la sicurezza delle informazioni a un livello appropriato durante le interruzioni.
5.30	Prontezza dell'ICT per la continuità operativa	Controllo La prontezza dell'ICT deve essere pianificata, attuata, mantenuta e testata sulla base degli obiettivi di continuità operativa e dei requisiti di continuità dell'ICT.

prospetto A.1 **Controlli per la sicurezza delle informazioni (Continua)**

5.31	Identificazione dei requisiti legali, statutari, regolamentari e contrattuali	Controllo I requisiti legali, statutari, regolamentari e contrattuali relativi alla sicurezza delle informazioni e l'approccio dell'organizzazione per soddisfare tali requisiti devono essere identificati, documentati e tenuti aggiornati.
5.32	Diritti di proprietà intellettuale	Controllo L'organizzazione deve attuare procedure appropriate per proteggere i diritti di proprietà intellettuale.
5.33	Protezione delle registrazioni	Controllo Le registrazioni devono essere protette da perdita, distruzione, falsificazione, accesso non autorizzato e rilascio non autorizzato.
5.34	Privacy e protezione dei dati personali	Controllo L'organizzazione deve identificare e soddisfare i requisiti relativi alla tutela della privacy e alla protezione dei dati personali secondo le leggi e i regolamenti applicabili e i requisiti contrattuali.
5.35	Riesame indipendente della sicurezza delle informazioni	Controllo L'approccio dell'organizzazione alla gestione della sicurezza delle informazioni e alla sua attuazione, che include personale, processi e tecnologie, deve essere riesaminato in modo indipendente a intervalli pianificati o quando si verificano cambiamenti significativi.
5.36	Conformità alle politiche e alle norme per la sicurezza delle informazioni	Controllo La conformità alla politica per la sicurezza delle informazioni dell'organizzazione, alle politiche specifiche, alle regole e agli standard deve essere riesaminata regolarmente.
5.37	Procedure operative documentate	Controllo Le procedure operative per le strutture di elaborazione delle informazioni devono essere documentate e messe a disposizione del personale che ne ha bisogno.
6	Controlli sul personale	
6.1	Screening	Controllo I controlli di verifica del background di tutti i candidati all'impiego devono essere effettuati prima dell'ingresso nell'organizzazione e su base continuativa, tenendo conto delle leggi, dei regolamenti e dell'etica applicabili ed essere proporzionati ai requisiti di business, alla classificazione delle informazioni a cui si deve accedere e ai rischi percepiti.
6.2	Termini e condizioni d'impiego	Controllo Gli accordi contrattuali di lavoro devono indicare le responsabilità del personale e dell'organizzazione relative alla sicurezza delle informazioni.
6.3	Consapevolezza, istruzione, formazione e addestramento sulla sicurezza delle informazioni	Controllo Il personale dell'organizzazione e le parti interessate pertinenti devono acquisire adeguate consapevolezza, istruzione e formazione relative alla sicurezza delle informazioni e aggiornamenti regolari della politica per la sicurezza delle informazioni dell'organizzazione, delle politiche specifiche e delle procedure, secondo quanto pertinente alla loro funzione lavorativa.
6.4	Processo disciplinare	Controllo Un processo disciplinare deve essere formalizzato e comunicato per intraprendere azioni contro il personale e altre parti interessate pertinenti che hanno commesso una violazione della politica per la sicurezza delle informazioni.
6.5	Responsabilità dopo la cessazione o il cambio d'impiego	Controllo Le responsabilità e gli obblighi in materia di sicurezza delle informazioni che rimangono validi dopo la cessazione o il cambio d'impiego devono essere definiti, applicati e comunicati al personale pertinente e alle altre parti interessate.
6.6	Accordi di riservatezza o di non divulgazione	Controllo Gli accordi di riservatezza o di non divulgazione che riflettono le esigenze dell'organizzazione per la protezione delle informazioni devono essere identificati, documentati, riesaminati regolarmente e firmati dal personale e dalle altre parti interessate pertinenti.
6.7	Lavoro a distanza	Controllo Quando il personale lavora a distanza, devono essere attuate misure di sicurezza per proteggere le informazioni a cui è possibile accedere o che sono elaborate o memorizzate al di fuori dei locali dell'organizzazione.

prospetto A.1 **Controlli per la sicurezza delle informazioni (Continua)**

6.8	Segnalazione degli eventi relativi alla sicurezza delle informazioni	Controllo L'organizzazione deve fornire un meccanismo che consenta al personale di segnalare tempestivamente, attraverso canali appropriati, gli eventi relativi alla sicurezza delle informazioni osservati o sospetti.
7	Controlli fisici	
7.1	Perimetro di sicurezza fisica	Controllo I perimetri di sicurezza devono essere definiti e utilizzati per proteggere le aree che contengono le informazioni e gli altri asset relativi.
7.2	Controlli di accesso fisico	Controllo Le aree sicure devono essere protette da adeguati controlli all'ingresso e ai punti di accesso.
7.3	Messa in sicurezza di uffici, locali e strutture	Controllo La sicurezza fisica di uffici, stanze e strutture deve essere progettata e attuata.
7.4	Monitoraggio della sicurezza fisica	Controllo Le sedi devono essere costantemente monitorate per l'accesso fisico non autorizzato.
7.5	Protezione dalle minacce fisiche e ambientali	Controllo Deve essere progettata e attuata la protezione contro le minacce fisiche e ambientali, come i disastri naturali e altre minacce fisiche intenzionali o non intenzionali all'infrastruttura.
7.6	Lavoro in aree sicure	Controllo Devono essere progettate e attuate misure di sicurezza per lavorare in aree sicure.
7.7	Schermo e scrivania puliti	Controllo Devono essere definite e opportunamente applicate regole chiare relative ai documenti cartacei e ai supporti di memorizzazione rimovibili e, per le strutture di elaborazione delle informazioni, regole chiare relative allo schermo.
7.8	Disposizione delle apparecchiature e loro protezione	Controllo Le apparecchiature devono essere posizionate in modo sicuro e protetto.
7.9	Sicurezza degli asset all'esterno delle sedi	Controllo Gli asset al di fuori delle sedi devono essere protetti.
7.10	Supporti di memorizzazione	Controllo I supporti di memorizzazione devono essere gestiti lungo tutto il loro ciclo di vita di acquisizione, uso, trasporto e smaltimento in conformità con lo schema di classificazione dell'organizzazione e con i requisiti di trattamento.
7.11	Infrastrutture di supporto	Controllo Le strutture di elaborazione delle informazioni devono essere protette da interruzioni di corrente e altre interruzioni causate da guasti nelle infrastrutture di supporto.
7.12	Sicurezza dei cablaggi	Controllo I cavi che trasportano alimentazione, dati o servizi informativi di supporto devono essere protetti da intercettazioni, interferenze o danni.
7.13	Manutenzione delle apparecchiature	Controllo Le apparecchiature devono essere mantenute correttamente per assicurare la disponibilità, l'integrità e la riservatezza delle informazioni.
7.14	Dismissione sicura o riutilizzo delle apparecchiature	Controllo Prima del loro smaltimento o riutilizzo, gli elementi delle apparecchiature contenenti supporti di memorizzazione devono essere verificati per assicurare che tutti i dati sensibili e il software in licenza siano stati rimossi o sovrascritti in modo sicuro.
8	Controlli tecnologici	
8.1	Endpoint degli utenti	Controllo Le informazioni memorizzate, elaborate o accessibili tramite gli endpoint degli utenti devono essere protette.
8.2	Diritti di accesso privilegiato	Controllo L'assegnazione e l'uso dei diritti di accesso privilegiato devono essere limitati e gestiti.
8.3	Limitazione degli accessi alle informazioni	Controllo Gli accessi alle informazioni e agli altri asset relativi devono essere limitati in conformità con la politica specifica per il controllo degli accessi.

prospetto A.1 **Controlli per la sicurezza delle informazioni (Continua)**

8.4	Accesso al codice sorgente	Controllo L'accesso in lettura e scrittura al codice sorgente, agli strumenti di sviluppo e alle librerie software deve essere gestito in modo appropriato.
8.5	Autenticazione sicura	Controllo Le tecnologie e le procedure di autenticazione sicura devono essere attuate in base alle limitazioni degli accessi alle informazioni e alla politica specifica per il controllo degli accessi.
8.6	Gestione della capacità	Controllo L'uso delle risorse deve essere monitorato e adeguato in linea con i requisiti di capacità attuali e previsti.
8.7	Protezione dal malware	Controllo La protezione dal malware deve essere attuata e supportata da un'adeguata consapevolezza degli utenti.
8.8	Gestione delle vulnerabilità tecniche	Controllo Si devono ottenere informazioni sulle vulnerabilità tecniche dei sistemi informativi in uso, valutare l'esposizione dell'organizzazione a tali vulnerabilità e adottare misure appropriate.
8.9	Gestione delle configurazioni	Controllo Le configurazioni, comprese le configurazioni di sicurezza, di hardware, software, servizi e reti devono essere stabilite, documentate, attuate, monitorate e riesaminate.
8.10	Cancellazione delle informazioni	Controllo Le informazioni memorizzate nei sistemi informatici, nei dispositivi o in qualsiasi altro supporto di memorizzazione devono essere cancellate quando non sono più necessarie.
8.11	Mascheramento dei dati	Controllo Il mascheramento dei dati deve essere utilizzato in conformità con la politica specifica dell'organizzazione per il controllo degli accessi e con gli altri requisiti specifici e di business correlati, tenendo in considerazione le norme di legge applicabili.
8.12	Prevenzione di leakage delle informazioni	Controllo Le misure di prevenzione di leakage dei dati devono essere applicate a sistemi, reti e qualsiasi altro dispositivo che elabora, memorizza o trasmette informazioni sensibili.
8.13	Backup delle informazioni	Controllo Le copie di backup di informazioni, software e sistemi devono essere mantenute e testate regolarmente secondo quanto stabilito dalla politica specifica per il backup.
8.14	Ridondanza delle strutture di elaborazione delle informazioni	Controllo Le strutture di elaborazione delle informazioni devono essere attuate con una ridondanza sufficiente a soddisfare i requisiti di disponibilità.
8.15	Raccolta di log	Controllo I log che registrano attività, eccezioni, guasti e altri eventi significativi devono essere prodotti, memorizzati, protetti e analizzati.
8.16	Attività di monitoraggio	Controllo Reti, sistemi e applicazioni devono essere monitorati relativamente a comportamenti anomali e dovrebbero essere intraprese azioni appropriate per valutare potenziali incidenti relativi alla sicurezza delle informazioni.
8.17	Sincronizzazione degli orologi	Controllo Gli orologi dei sistemi di elaborazione delle informazioni utilizzati dall'organizzazione devono essere sincronizzati con origini temporali approvate.
8.18	Utilizzo di programmi di utilità privilegiati	Controllo L'uso di programmi di utilità che possono essere in grado di ignorare i controlli del sistema e delle applicazioni deve essere limitato e strettamente controllato.
8.19	Installazione del software sui sistemi in esercizio	Controllo Devono essere attuate procedure e misure per gestire in modo sicuro l'installazione del software sui sistemi in esercizio.
8.20	Sicurezza delle reti	Controllo Le reti e i dispositivi di rete devono essere protetti, gestiti e controllati per proteggere le informazioni nei sistemi e nelle applicazioni.
8.21	Sicurezza dei servizi di rete	Controllo I meccanismi di sicurezza, i livelli di servizio e i requisiti dei servizi di rete devono essere identificati, attuati e monitorati.

prospetto A.1 **Controlli per la sicurezza delle informazioni** (Continua)

8.22	Segregazione delle reti	Controllo I gruppi di servizi informativi, di utenti e di sistemi informativi devono essere segregati nelle reti dell'organizzazione.
8.23	Web filtering	Controllo L'accesso a siti web esterni deve essere gestito per ridurre l'esposizione a contenuti dannosi.
8.24	Uso della crittografia	Controllo Per l'uso efficace della crittografia devono essere definite e attuate regole, inclusa la gestione delle chiavi crittografiche.
8.25	Ciclo di vita dello sviluppo sicuro	Controllo Devono essere stabilite e applicate regole per lo sviluppo sicuro di software e sistemi.
8.26	Requisiti di sicurezza delle applicazioni	Controllo I requisiti di sicurezza delle informazioni devono essere identificati, specificati e approvati durante lo sviluppo o l'acquisizione di applicazioni.
8.27	Sicurezza dell'architettura dei sistemi e dei principi di ingegnerizzazione	Controllo I principi per l'ingegnerizzazione di sistemi sicuri devono essere stabiliti, documentati, mantenuti e applicati a qualsiasi attività di sviluppo dei sistemi informativi.
8.28	Sviluppo sicuro	Controllo I principi di sviluppo sicuro devono essere applicati allo sviluppo del software.
8.29	Test di sicurezza in fase di sviluppo e di accettazione	Controllo I processi di test di sicurezza devono essere definiti e attuati nel ciclo di vita dello sviluppo.
8.30	Sviluppo affidato all'esterno	Controllo L'organizzazione deve dirigere, monitorare e riesaminare le attività di sviluppo dei sistemi affidate all'esterno.
8.31	Separazione degli ambienti di sviluppo, test e produzione	Controllo Gli ambienti di sviluppo, test e produzione devono essere separati e protetti.
8.32	Gestione dei cambiamenti	Controllo I cambiamenti alle strutture di elaborazione delle informazioni e ai sistemi informativi devono essere soggetti a procedure di gestione dei cambiamenti.
8.33	Dati di test	Controllo I dati di test devono essere scelti, protetti e gestiti opportunamente.
8.34	Protezione dei sistemi informativi durante i test di audit	Controllo I test di audit e le altre attività di garanzia che prevedono la valutazione dei sistemi di produzione devono essere pianificati e concordati tra chi li effettua e l'appropriato livello manageriale.

BIBLIOGRAFIA

- [1] UNI CEI ISO/IEC 27002:2023 Sicurezza delle informazioni, cybersecurity e protezione della privacy - Controlli per la sicurezza delle informazioni
- [2] ISO/IEC 27003 Information technology - Security techniques - Information security management systems - Guidance
- [3] ISO/IEC 27004 Information technology - Security techniques - Information security management - Monitoring, measurement, analysis and evaluation
- [4] ISO/IEC 27005 Information security, cybersecurity and privacy protection - Guidance on managing information security risks
- [5] UNI ISO 31000:2018 Gestione del rischio - Linee guida



UNI Ente Italiano di Normazione
Membro italiano ISO e CEN

Via Sannio, 2 - 20137 Milano
Via del Collegio Capranica, 4 - 00186 Roma

www.uni.com



normeUNI



@normeUNI



normeUNI